

Lab Answers: Suspected DPRK IT Worker (Insider Threat)

In this lab, no single indicator is enough. You won't find an IOC. You'll have to string together enough evidence to determine if the risk is high enough to respond to the threat. We're operating on the hypothesis that we let an insider threat (DPRK IT Worker) into our network and gave them an endpoint.

We will begin our investigation by examining the user's search history, as it often reveals significant insight into their intentions and interests. There are numerous search engines:

- Google
- Bing
- Yahoo
- DuckDuckGo
- Yandex
- Brave
- Startpage
- Ecosia
- Etc.

If you spend enough time examining search engine traffic, you'll identify a common pattern. Most search engines use the `q=` parameter in the URL to pass along the search phrase. For example:

Google

Test Phrase: TEST123

URL: `https://www.google.com/search?q=TEST123&...`

Bing

Test Phrase: HELLO WORLD!

URL: `https://www.bing.com/search?q=HELLO+WORLD%21&...`

In Bash, you could use `awk` to match one of the search engines hostnames, then extract the search phrase, however the command gets complex and the output isn't easy to read.

As an added feature to show the flexibility and capabilities of a well crafted hunting notebook, there's also a wordlist (`dirty_wordlist.txt`) in the `/data/` directory with a list of search phrases that might help you catch a DPRK IT Worker. Review the text file and modify / add keywords to the `dirty_wordlist.txt` file. What phrases would you want to highlight in users' search engine activity that could indicate an insider threat?

When you run the `search_engine_hunter.ipynb`, you'll not only see the search terms parsed out for you, you'll also see if any of the transactions match to suspicious search phrases in the `dirty_wordlist.txt` file.

At the bottom of the notebook, you can use the interactive user interface to filter the search engine, users, rows, search terms, or only show searches that match to a phrase on the `dirty_wordlist.txt` file.

Engine:

All

☐ Only dirty matches

User:

Filter by user contains (e.g., karer

Term:

Search terms contains (e.g., bypa

Rows: 50

Filtered searches
38

Unique terms
37

Dirty hits
7

Search engine volume (filtered)

	Logged Time	User	URL	search_engine	search_term	domain
146	January 27, 2026 2:32:26 PM PST	karen@acme.zscaler.net	www.google.com/search?q=chatgpt&sca_esv=ac8dc9...	Google	chatgpt	google.com
153	January 27, 2026 2:32:26 PM PST	karen@acme.zscaler.net	www.google.com/search?q=chatgpt&sca_esv=ac8dc9...	Google	chatgpt	google.com
275	January 27, 2026 2:32:33 PM PST	karen@acme.zscaler.net	www.google.com/search?q=chatgpt+alternative&sa...	Google	chatgpt alternative	google.com
414	January 27, 2026 2:32:42 PM PST	karen@acme.zscaler.net	www.google.com/search?q=perplexity+ai&safe=a...	Google	perplexity ai	google.com
525	January 27, 2026 2:32:49 PM PST	karen@acme.zscaler.net	www.google.com/search?q=chatsonic&safe=active&...	Google	chatsonic	google.com
812	January 27, 2026 2:37:45 PM PST	karen@acme.zscaler.net	www.google.com/search?q=pomoduro+with+notes&sa...	Google	pomoduro with notes	google.com
1120	January 27, 2026 2:38:12 PM PST	karen@acme.zscaler.net	www.google.com/search?client=firefox-b-1-d&q=c...	Google	codeshare	google.com
1248	January 27, 2026 2:38:35 PM PST	karen@acme.zscaler.net	www.google.com/search?client=firefox-b-1-d&q=c...	Google	canva	google.com
1323	January 27, 2026 2:38:40 PM PST	karen@acme.zscaler.net	www.google.com/search?q=canva+free&safe=active...	Google	canva free	google.com
1382	January 27, 2026 2:38:42 PM PST	karen@acme.zscaler.net	www.google.com/search?q=canva+free+trial&safe=...	Google	canva free trial	google.com

In the notebook, you'll be able to identify searches that match the dirty wordlist phrases. Additionally, examining all search phrases, several searches raise suspicion. For example:

- Canva - repeated searches and completions for “canva free” and “canva free trial”. DPRK IT Workers often use Canva/Adobe to forge documentation or generate HR artifacts. Searching specifically for “free trial” can indicate burner-account behavior (cycling accounts), which is consistent with operators who want capability without traceable billing.
- ChatGPT Alternatives - the user is provided with an authorized GenAI tool. Looking for alternatives may be an indication of detection evasion where the user wants to use GenAI outside the monitoring of IT/InfoSec.
- Parsec - the user searches for remote desktop software, possibly for access to the corporate device that’s located in a laptop farm.
- Kali Linux VM - the user searches for offensive tooling.
- Time in San Jose - given the employee is officially recorded as hired in San Jose, CA, checking “time in san jose” can be a weak signal of someone trying to operate consistently with a claimed location/timezone (especially if they are actually abroad). It’s not a smoking gun as people check time zones when working with global teams, but it becomes more relevant when paired with remote access + identity/finance signals.
- Money transfer - searches like: “cashapp” and “white label money transfer app similar to cashapp free” (and variations) are observed in DPRK IT Worker operations and often involve moving income via intermediaries and/or crypto rails. The combination of: “white label money transfer app” research (suggesting interest in payments infrastructure / transfer mechanisms), followed by real crypto/finance site access, occurring during the same window as remote-access tooling can fit a narrative of operational finance handling + remote operational setup, rather than role-focused GenAI development.
- PDF Editor - searches: “free pdf editor w1”, “free pdf editor w2”. Free PDF editors are frequently used by DPRK IT Workers to modify forms, IDs, contracts, invoices, onboarding docs, etc. This is a classic weak signal that becomes meaningful when correlated with other signals.

These searches give us numerous threads to pivot on.

	search_engine	search_term	is_dirty	dirty_hits
146	Google	chatgpt	False	[]
153	Google	chatgpt	False	[]
275	Google	chatgpt alternative	False	[]
414	Google	perplexity ai	False	[]
525	Google	chatsonic	False	[]
812	Google	pomoduro with notes	False	[]
1120	Google	codeshare	False	[]
1248	Google	canva	False	[]
1323	Google	canva free	False	[]
1382	Google	canva free trial	False	[]
1530	Google	white label money transfer app similar to cahs...	True	[money transfer]
1797	Google	cashapp	False	[]
1887	Google	how to take a screenshot on mac	False	[]
2037	Google	white label money transfer app similar ot cash...	True	[money transfer]
2144	Google	google meet	False	[]
3697	Google	parsec	False	[]
3812	Google	parsec download	False	[]
4002	Google	parsec definition	False	[]
4138	Google	parsec download dekstop	False	[]
4257	Google	mitm proxy	False	[]
4325	Google	mitm proxy video	False	[]
4517	Google	kali linux vm	False	[]
4733	Google	curl https://cdimage.kali.org/kali-2025.4/kali...	False	[]
4850	Google	kocowa	False	[]
5128	Google	time in san jose	False	[]

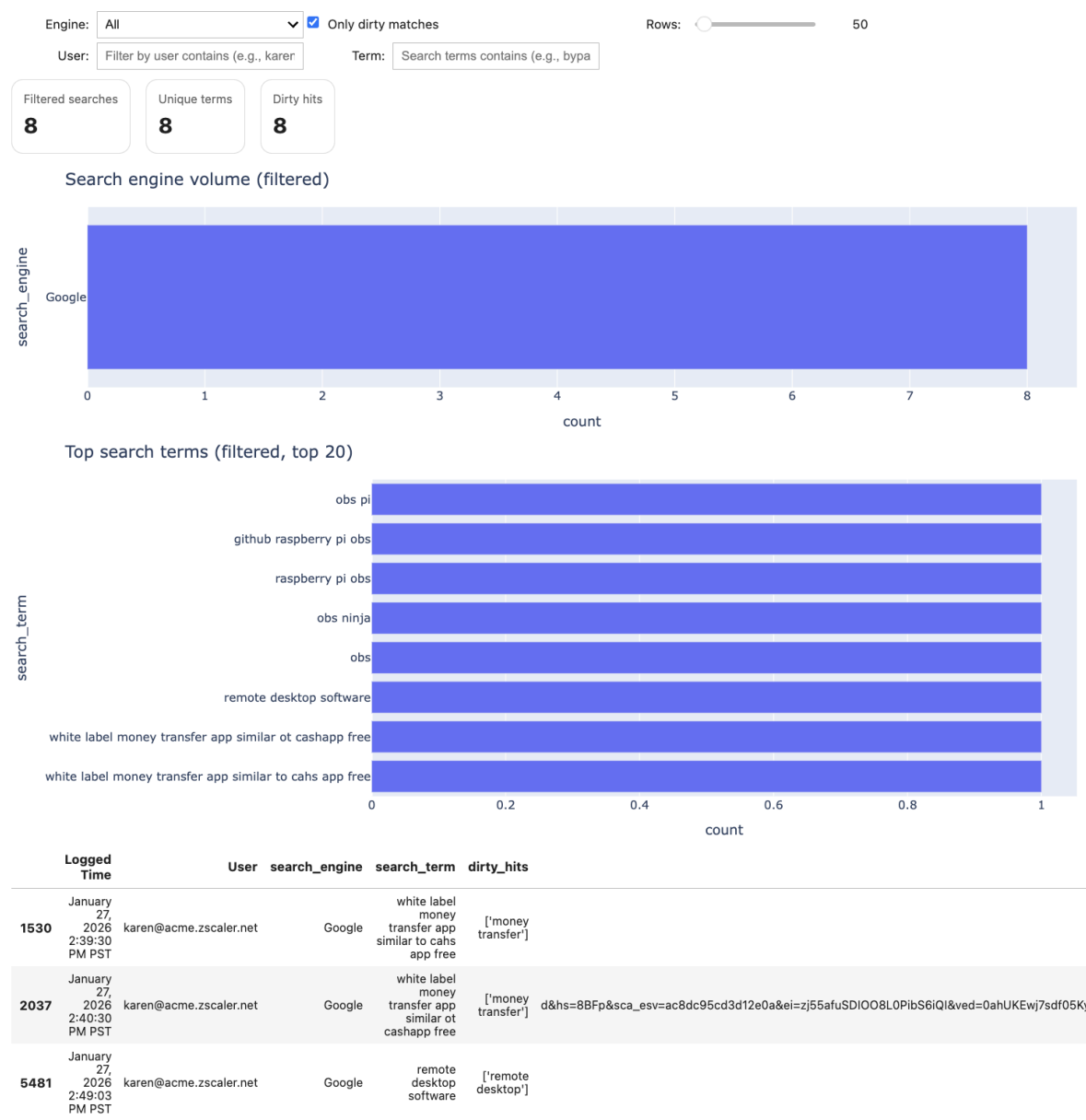
Searches: “mitm proxy”, “mitm proxy video” in addition to direct access to docs.mitmproxy.org/stable/mitmproxytutorial-replayrequests/ Could fit the profile of a DPRK IT Worker for several reasons / use cases.

Mitmproxy “replay requests” content is often used to reproduce/modify web traffic. In insider scenarios, that can map to:

- bypassing controls (session replay, API manipulation),

- automation/scripting of authenticated actions,
- testing how to extract or replay data flows.

When this appears right next to remote-access activity, it can look like preparation for stealthy access + control + traffic manipulation rather than normal GenAI development activity.



Google searches like “parsec download”, “parsec download dekstop” (likely typo), and related completions.

Searching for “remote” and “remotedesktop” in the workbench notebook, we can quickly identify additional risky transactions indicating possible unsanctioned remote desktop activity:

Event Time	User	URL	URL Category	Policy Action	Status	User Agent	Client IP	Client External IP
January 27, 2026 2:49:20 PM PST	karen@acme.zscaler.net	www.google.com/url?sa=t&source=web&rct=j&opi=8...	Web Search	Allowed	NaN	Firefox (133.0) (Mozilla/5.0 (Windows NT 10.0; ...	10.0.0.92	172.251.234.34
January 27, 2026 2:49:20 PM PST	karen@acme.zscaler.net	remotedesktop.google.com	Remote Access Tools	Dropped due to failed client SSL handshake	NaN	Unknown	10.0.0.92	172.251.234.34
January 27, 2026 2:49:20 PM PST	karen@acme.zscaler.net	www.google.com/gen_204?atyp=i&ei=3kB5aYCyMPnNk...	Web Search	Allowed	NaN	Firefox (133.0) (Mozilla/5.0 (Windows NT 10.0; ...	10.0.0.92	172.251.234.34
January 27, 2026 2:49:24 PM PST	karen@acme.zscaler.net	remotedesktop.google.com/	Remote Access Tools	Allowed	Unsanctioned	Firefox (133.0) (Mozilla/5.0 (Windows NT 10.0; ...	10.0.0.92	172.251.234.34

The user visits `parsec.app` and `parsec.app/downloads` (URL Category: Remote Access Tools).

The user also visits `remotedesktop.google.com` (URL Category: Remote Access Tools).

Two separate remote-access products in the same short window is a strong “weak-signal”. It looks less like “remote work with Zoom” and more like operational remote access (e.g., accessing a second machine, maintaining redundancy, or troubleshooting a remote “jump box” in a laptop farm).

DPRK IT Worker tradecraft commonly includes laptop-farm / remote relay patterns. Seeing Parsec and Chrome Remote Desktop close together can fit the profile of a DPRK IT Worker.

Pivoting to a thin tail analysis, several additional hostnames of interest are identified:

Pivot Explorer (filtered)

Pivot: Hostname

Top N:

30

Filtered rows: 8,080 / 8,080

	Hostname	Count
0	firefox.com	3784
1	google.com	2369
2	172.184.91.6	356
3	youtube.com	247
4	pomofocus.io	176
5	coinbase.com	135
6	microsoft.com	103
7	kocowa.com	77
8	sdk.finance	72
9	obsproject.com	71
10	bing.com	64
11	live.com	56
12	kali.org	56
13	ka.app	47
14	codeshare.io	42
15	brendacadman.com	38
16	gstatic.com	35
17	portswigger.net	28
18	raspberrypi.com	28
19	parsec.app	27
20	googleapis.com	19
21	notesnook.com	14

The user visits to www.kali.org/get-kali/ and many supporting assets (URL Super Category: Security). Kali is strongly associated with penetration testing / offensive tooling. In isolation, a security-curious developer might browse it. But combined with:

- mitmproxy replay-request tutorial
- remote-access tool stacking

This cluster of activity can support a hypothesis of capability-building for bypass / intrusion enablement rather than job-aligned activity.

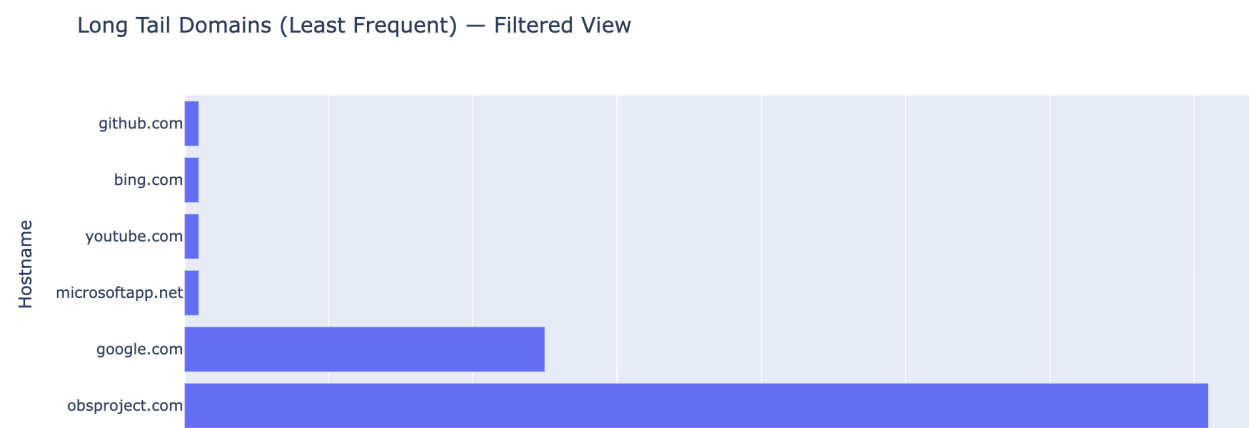
Search: obs

Search in:

request method
Policy Action
Client IP
Client External IP
Server IP
Referrer URL
Download File Type
Download File Name
URL Category
Threat Name

Apply Filters

Reset

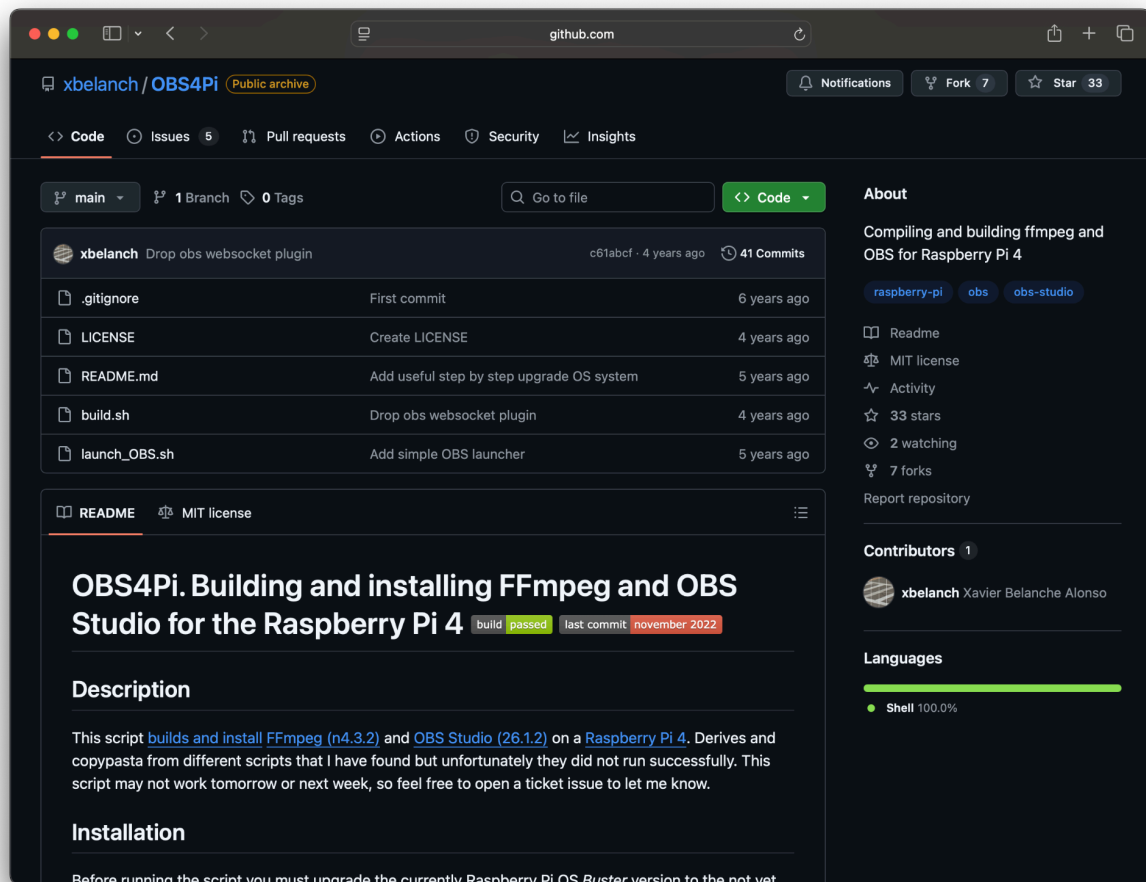


We also see GitHub activity. If we filter by URL or Hostname and search for “github”, we can see several concerning repos relating to OBS and note taking. If you recall, there were Google searches for: “pomoduro with notes” (likely intended “pomodoro with notes”). DPRK IT Workers sometimes use unsanctioned note-taking tools for exfiltration / cross-company work.

Since Evernote is approved, searching for other “with notes” tooling can be a weak signal of parallel workflow tooling (especially if it leads to an unsanctioned platform later).

	Event Time	User	URL	URL Category	Policy Action	Status	User Agent	Client IP	Client External IP
6649	January 27, 2026 2:52:14 PM PST	karen@acme.zscaler.net	github.com	Professional Services	Dropped due to failed client SSL handshake	NaN	Unknown	10.0.0.92	172.251.234.34
6657	January 27, 2026 2:52:18 PM PST	karen@acme.zscaler.net	github.com/streetwriters/notesnook	Professional Services	Allowed	Unsanctioned	Firefox (133.0) (Mozilla/5.0 (Windows NT 10.0; ...	10.0.0.92	172.251.234.34
6658	January 27, 2026 2:52:18 PM PST	karen@acme.zscaler.net	github.githubassets.com	Other Information Technology	Dropped due to failed client SSL handshake	NaN	Unknown	10.0.0.92	172.251.234.34
6659	January 27, 2026 2:52:18 PM PST	karen@acme.zscaler.net	avatars.githubusercontent.com	Professional Services	Dropped due to failed client SSL handshake	NaN	Unknown	10.0.0.92	172.251.234.34
6696	January 27, 2026 2:52:20 PM PST	karen@acme.zscaler.net	avatars.githubusercontent.com	Professional Services	Dropped due to failed client SSL handshake	NaN	Unknown	10.0.0.92	172.251.234.34
6697	January 27, 2026 2:52:20 PM PST	karen@acme.zscaler.net	github.com/streetwriters/notesnook/raw/master/...	Professional Services	Allowed	Unsanctioned	Firefox (133.0) (Mozilla/5.0 (Windows NT 10.0; ...	10.0.0.92	172.251.234.34
6702	January 27, 2026 2:52:20 PM PST	karen@acme.zscaler.net	raw.githubusercontent.com	FileHost	Dropped due to failed client SSL handshake	NaN	Unknown	10.0.0.92	172.251.234.34
6705	January 27, 2026 2:52:20 PM PST	karen@acme.zscaler.net	github.com/fluidicon.png	Professional Services	Allowed	Unsanctioned	Firefox (133.0) (Mozilla/5.0 (Windows NT 10.0; ...	10.0.0.92	172.251.234.34
7063	January 27, 2026 2:53:41	karen@acme.zscaler.net	release-assets.githubusercontent.com	Professional Services	Dropped due to failed client SSL	NaN	Unknown	10.0.0.92	172.251.234.34

If we analyze some of the repos accessed, we can see that the OBS repo is for OBS4Pi. The combination of OBS4Pi + Raspberry Pi offers DPRK IT Workers a dirt-cheap, ultra-low-profile way to fake a visible workstation for video calls, run background streams, or maintain cover personas.



Public reports (e.g. Disrupting malicious uses of AI: June 2025), indicate DPRK IT Workers “...researched using tools such as Tailscale peer-to-peer VPN, OBS Studio, vdo.ninja live-feed injection, and HDMI capture loops as part of their operations. These tools have the potential to be used to circumvent corporate security measures, and if successful, they would allow someone to maintain a persistent, undetected remote presence, as well as attempt to bypass some identity verification processes that rely on live video meetings.”

The Internet is littered with references to OBS and Raspberry Pi devices relating to DPRK IT Workers and North Korean state-sponsored actors. For example, [The Hacker News](#) reports: “KnowBe4 said it detected suspicious activities on the Mac workstation sent to the individual on July 15, 2024, at 9:55 p.m. EST that consisted of manipulating session history files, transferring potentially harmful files, and executing harmful software. The malware was downloaded using a Raspberry Pi.”

Pivoting to a stack rank of “Download File Names”, we can again see indication of the unsanctioned note taking tool being downloaded and the OBS installer, further validating our hypothesis.

Pivot: Download File Name		Top N: 10	30
Filtered rows: 8,080 / 8,080			
	Download File Name	Count	
0	NaN	5671	
1	success.txt	1894	
2	f.txt	413	
3	response.bin	13	
4	favicon.ico	8	
5	connecttest.txt	6	
6	notesnook_win_x64.exe	4	
7	example-user3.mp4	3	
8	example-user2.mp4	3	
9	example-code.mp4	3	
10	example-user1.mp4	3	
11	1ptug8zys_skggpnyc0it4ttdfa.woff2	2	
12	login.json	2	
13	obs-studio-32.0.4-windows-x64-installer.exe	2	
14	config.json	1	
15	arial_rounded_mt.ttf	1	
16	arial-rounded-mt-bold.ttf	1	
17	button.wav	1	
18	raleway-v13-latin-regular.woff2	1	
19	cinzel-v8-latin-regular.woff2	1	
20	libre-baskerville-v6-latin-italic.woff2	1	
21	raleway-v13-latin-300.woff2	1	
22	about-brenda-lg.webp	1	
23	1pt_g8zys_skggpnycsqamb1w0lwk4s4wjmdrmfib1zyc...	1	
24	raleway-v13-latin-500.woff2	1	
25	cropped-favicon-1-192x192.webp	1	
26	cropped-favicon-1-32x32.webp	1	
27	fpconfig.min.json	1	
28	rubik-regular.woff2	1	

Analyzing the TLDs, one stands out as uncommon (.ninja). Pivoting on hostnames with the TLD of .ninja, we can see interactions with vdo.ninja.

VDO.Ninja (often stylized as VDO.Ninja or obs.ninja in older references) is a free, browser-based, peer-to-peer WebRTC tool created by Steve Seguin. It allows low-latency sharing of live video, audio, and screens from almost any device (phone, laptop, Raspberry Pi, etc.) directly into software like OBS Studio, without needing accounts, installs, or centralized servers in most cases.

In essence, VDO.Ninja acts as the "video transport layer" that makes the fake in-person presence more convincing and resilient. Combined with obs4pi/Raspberry Pi, it turns ultra-cheap hardware into a believable remote-work facade

threat-hunting-lab-zia [Codespace]

hunter_workbench.ipynb M majestic_million_enrichment.i

otebooks > majestic_million_enrichment.ipynb > # -----

Generate + Code + Markdown | Run All Restart

View: Top Domains (Stack Count) Top N:

Search: Filter: domain contains (e.g. disco) TLD:

Policy: All Method:

☐ Show ONLY domains NOT in Majestic Million

☒ Highlight domains not in Majestic ☒ Highlight uncommon TLDs

Filtered Events
13

Unique Domains
1

Unique TLDs
1

NOT in Majestic
0

Top Domains (stack count) — top 35

All
app
co
com
ee
finance
io
microsoft
net
✓ **ninja**
org
tech
us

Sample events for: **vdo.ninja**

	Logged Time	User	URL	domain	tld	Request Method	Response Code	Policy Action
7156	January 27, 2026 2:53:54 PM PST	karen@acme.zscaler.net	vdo.ninja	vdo.ninja	ninja	nan	nan	Dropped due to failed client SSL handshake
7178	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/	vdo.ninja	ninja	GET	200 - OK	Allowed
7180	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/main.css?ver=4034	vdo.ninja	ninja	GET	200 - OK	Allowed
7181	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/auth-styles.css	vdo.ninja	ninja	GET	200 - OK	Allowed
7182	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/thirdparty/codecsandler.js?ver=29	vdo.ninja	ninja	GET	200 - OK	Allowed
7183	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/thirdparty/aes.js	vdo.ninja	ninja	GET	200 - OK	Allowed
7184	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/thirdparty/adaptter.js	vdo.ninja	ninja	GET	200 - OK	Allowed
7185	January 27, 2026 2:53:57 PM PST	karen@acme.zscaler.net	vdo.ninja/webtrc.js?ver=912	vdo.ninja	ninja	GET	200 - OK	Allowed
7230	January 27, 2026 2:54:01 PM PST	karen@acme.zscaler.net	vdo.ninja/media/favicon-32x32.png	vdo.ninja	ninja	GET	200 - OK	Allowed
7565	January 27, 2026 2:54:54 PM PST	karen@acme.zscaler.net	vdo.ninja/cdn-cgi/scripts/5c5dd728/cloudflare-static/email-decode.min.js	vdo.ninja	ninja	GET	200 - OK	Allowed